

SBOM “by design” – Integrating S/W Transparency into CI/CD

GEORGIADOU Ioanna
Cyber Security Officer
Market Technology and Product Security Unit, ENISA

27th October 2026

With you today

Georgiadou Ioanna

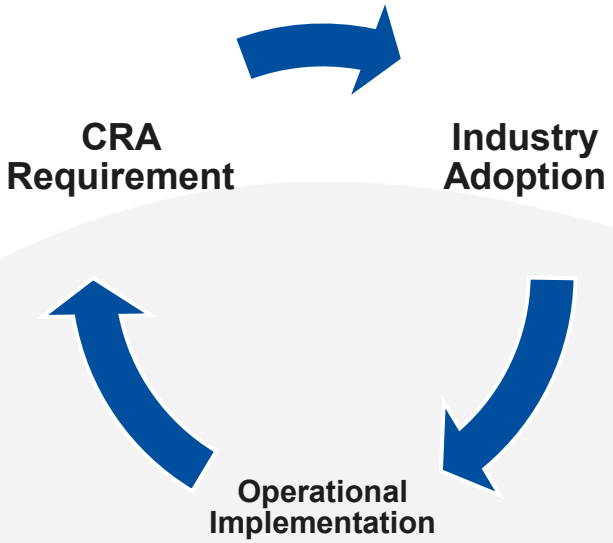
- ✓ Cybersecurity Officer at ENISA
- ✓ Market, Technology and Product Security Unit
- ✓ 10 years of experience in Cybersecurity across industries
- ✓ M.Sc. Cyber Security and Management
- ✓ B.Eng. Computer Science and Engineering

The Context

From obligation to operational capability

The **Cyber Resilience Act** places software transparency and vulnerability management firmly within manufacturers' cybersecurity responsibilities.

At the same time, organisations are **increasingly adopting SBOMs** to gain visibility into the software components on which their products depend.



The Challenge is shifting..

Yesterday: Should we produce SBOMs?

Today: How do we produce reliable SBOMs at scale?

Tomorrow: How do we use SBOM data to improve security and manage software supply-chain risk?

The Evidence

Adoption is accelerating! Maturity remains limited.

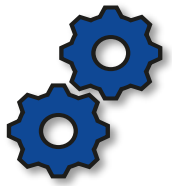
The **SBOM Adoption State of play 2026** shows a strong momentum but also a clear implementation gap.



78 % **have already initiated their SBOM adoption journey**



44 % **remain at pilot / limited adoption**



67 % report a moderate or significant gap between **SBOM generation and utilisation**



Request for Technical Guidance and support!

“Adoption is progressing faster than operational maturity”

SBOM “by Design”: Why it matters

From SBOM generation to continuous management

Software supply chains are **complex**, **interconnected**, and **constantly evolving**.

Traditional approach: standalone activity, performed towards the end of the software development process or in response to a compliance requirement.

Limitations:

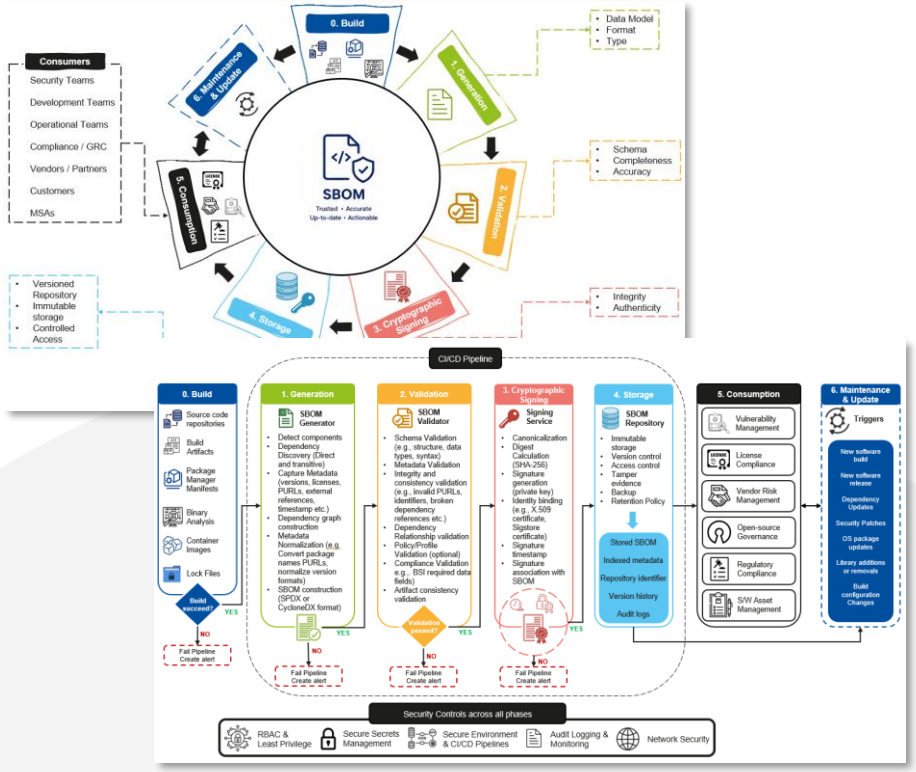
- ✓ **Point-in-time visibility**: SBOMs may become outdated as components and dependencies change.
- ✓ **Limited trustworthiness**: Incomplete component discovery, weak identifiers, or missing validation undermine reliability.
- ✓ **Limited operational value**: SBOMs that are not integrated with security processes may remain unused.

Software transparency should be embedded into software engineering processes, not treated as a one-off compliance activity.

The Technical Advisory

Turning knowledge to actionable implementation

The Advisory brings together standards, implementation practices and security considerations into a single end-to-end approach.



Practical Questions

- How do I automatically generate an SBOM for every build/release?
- How do I know the SBOM is syntactically valid, complete and accurate?
- How do I know this SBOM is authentic and belongs to this artifact?
- Where do I retain SBOMs and their historical versions?
- What security processes actually use the information?

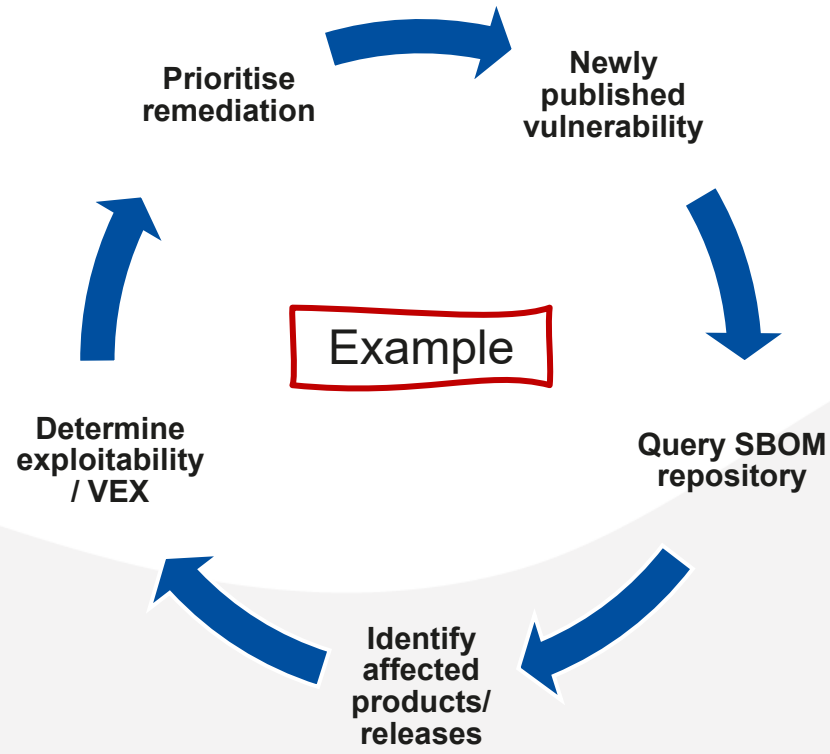
The Value

Generation is not the destination, consumption is!

The question now shifts from “How do I generate an SBOM?” to “What do I do with it?”.

SBOM Consumption

- ✓ S/W Asset Inventory
- ✓ Vulnerability Management
- ✓ License Compliance
- ✓ Vendor Risk Management
- ✓ Open-source Governance
- ✓ Regulatory Compliance



The Challenges

Automation cannot solve them all!

Automating SBOM generation is a starting point, not a guarantee of software transparency.

Component Definition

Component Identification

Vulnerability Correlation

Completeness & Accuracy

Tool Reliability

Automation is essential for scalability, but it cannot compensate for fundamental limitations in the underlying information or the tools processing it.

ENISA Way Forward

Build the foundation for an implementation pathway

Understand

- **SBOM Adoption State of Play (Published June 2026)**
- Evidence on adoption, challenges and industry needs

Guide

- **Technical Advisory for SBOM (Published October 2026)**
- Implementation guidance based on standards and best practices

Demonstrate

- **SBOM Reference Implementation**
- Present how the SBOM lifecycle can work in a real CI/CD pipeline

Operationalize

- **Technical Advisory for VEX (Open Consultation November 2026)**
- Enable organisations to turn S/W transparency into actionable security information

Support

- ✓ **Manufacturers** and product builders
- ✓ **Practitioners** responsible for designing, building, and maintaining products with digital elements

enisa
EUROPEAN UNION AGENCY FOR CYBERSECURITY

Thank you for your attention

 +30 28 14 40 9711

 product_security@enisa.europa.eu

 enisa.europa.eu

ENISA
European Union Agency
for Cybersecurity

Athens Office
Agamemnonos 14
Chalandri 15231, Attiki, Greece

Brussels Office
Rue de la Loi 107
1049 Brussels, Belgium